

primary

Lecture Notes

Cyber Security & Digital Forensics

CSE-4207 | Lecture 02

Dr. Md. Alam Hossain
Professor, Department of CSE
Jashore University of Science & Technology

Contents

1	Introduction to Cyber Crime	2
1.1	Core Categories of Cyber Crime	2
1.2	Types of Cyber Crime	3
1.3	Motivations Behind Attacks	3
1.4	Distributed Attacks & Malware Growth	3
2	Hacking	4
2.1	Types of Hackers	4
2.2	Skills of an Ethical Hacker	4
3	Ethical Hacking	5
3.1	Why Organizations Recruit Ethical Hackers	5
3.2	Questions an Ethical Hacker Tries to Answer	5
4	Hacking Terminology (Key Concepts)	6
4.1	The Five Phases of Hacking	7
5	Incident Management	8
5.1	Components of Incident Management	8
5.2	Eight Steps of Incident Handling	8
5.3	Responsibilities of the Incident Management Team	8
6	Vulnerability Assessment	9
6.1	Types of Vulnerability Assessment	10
6.2	Network Vulnerability Assessment Method (5 Phases)	10
6.3	Vulnerability Research	11
7	Penetration Testing	11
7.1	Why Penetration Testing?	12
7.2	Types of Penetration Testing	12
7.3	Phases of Penetration Testing	12
7.4	Types of Penetration Tests (Scope-Based)	13

1 Introduction to Cyber Crime

What is Cyber Crime?

Cyber crime means **offences against computer data and systems** — any illegal or harmful activity done using a computer or a network.

1.1 Core Categories of Cyber Crime

1. **Illegal Access** — Getting into a computer, system, or account *without permission*. You can think of it like digital trespassing.
2. **Illegal Interception** — Secretly listening to, capturing, or stealing data while it is moving between two parties (e.g., capturing login credentials over Wi-Fi).
3. **Data Interference** — Changing, deleting, or damaging stored data without authorization (e.g., damaging/corrupting a database).
4. **System Interference** — Disrupting or crashing computer systems or whole networks so they stop being available to users (e.g., DDoS attacks).
5. **Misuse of Devices** — Using hacking tools, exploit kits, or malicious devices for illegal purposes (e.g., making and selling keyloggers).

1.2 Types of Cyber Crime

Type	Description
Hacking	Gaining unauthorized access to a computer or network.
Denial-of-Service (DoS) Attack	Overloading a system so it stops working properly (service becomes unavailable).
Virus Dissemination	Intentionally spreading harmful software (viruses, worms, ransomware).
Computer Vandalism	Purposely damaging or destroying data or computer systems.
Cyber Terrorism	Using cyber attacks to create large-scale fear or to harm governments / organizations.
Software Piracy	Copying or using software without a valid license.

1.3 Motivations Behind Attacks

$$\text{Attacks} = \text{Motive (Goal)} + \text{Method} + \text{Vulnerability}$$

A motive starts because the attacker believes the *target system stores or processes something valuable*. Common motives include:

- Disrupting business continuity
- Information theft
- Manipulating / destroying data
- Creating fear by disrupting critical infrastructure
- Propagating religious or political beliefs
- Achieving a state's military objectives
- Damaging the reputation of a target
- Taking revenge

1.4 Distributed Attacks & Malware Growth

Distributed attacks use many compromised machines together to launch an attack at the same time. Common distributed malware types include **Viruses** ($\approx 49\%$), **Trojans** ($\approx 30\%$), and **Worms** ($\approx 12\%$). The worldwide number of new malware samples (specimens) grew from ≈ 0.13 million in 2007 to over 7 million by 2017, which shows how fast the threat landscape has expanded.

2 Hacking

Hacking Defined

Hacking is the process of **finding and exploiting system vulnerabilities and bypassing security controls** to get unauthorized or inappropriate access to system resources. It can also involve changing system or application features to achieve a goal *outside the creator's original purpose*, and it may be used to steal or redistribute intellectual property.

2.1 Types of Hackers

Hacker Type	Description
Black Hats	Individuals with exceptional computing skills who engage in <i>malicious or destructive</i> activities. Also called <i>crackers</i> .
White Hats	Professionals who use hacking skills <i>for defence</i> to protect systems. Also known as <i>security analysts</i> or ethical hackers.
Gray Hats	Work <i>both offensively and defensively</i> at various times; not purely malicious or purely ethical.
Suicide Hackers	Try to bring down critical infrastructure for a “cause” and do not care about legal consequences.
Script Kiddies	Unskilled attackers who use scripts and tools made by real hackers, with little understanding of how they work.
Cyber Terrorists	Highly skilled individuals motivated by religious or political beliefs who seek large-scale disruption.
State-Sponsored Hackers	Employed by governments to conduct espionage, steal secrets, or damage another nation's information systems.
Hactivists	Push a political agenda through hacking, often by defacing or disabling websites.

2.2 Skills of an Ethical Hacker

Technical Skills

- Deep knowledge of major OS: Windows, Unix, Linux, macOS
- Good understanding of networking, hardware & software
- Strong technical expertise in computing areas
- Understanding of security areas & related issues
- Enough “high-technical” knowledge to carry out sophisticated attacks

Non-Technical Skills

- Ability to learn and adapt to new technologies quickly
- Strong work ethics; good problem-solving & communication
- Commitment to the organization’s security policies
- Awareness of local laws and regulations

3 Ethical Hacking

What is Ethical Hacking?

Ethical hacking means using hacking tools, tricks, and techniques to **find vulnerabilities** in order to **keep systems secure**. It focuses on simulating the techniques real attackers use, to confirm the *existence of vulnerabilities that can be exploited*. Ethical hackers perform security assessments **with the permission of concerned authorities**.

Core Philosophy

“To beat a hacker, you need to think like one!”

Ethical hacking is necessary because it allows organizations to *counter attacks from malicious hackers* by predicting and preparing for the methods used to break into a system.

3.1 Why Organizations Recruit Ethical Hackers

1. To **stop hackers** from getting into the organization’s information systems.
2. To **find vulnerabilities** in systems and understand how risky they could be.
3. To analyze and **improve the organization’s security posture**, including policies, network protection infrastructure, and end-user practices.

3.2 Questions an Ethical Hacker Tries to Answer

- What can an intruder *see* on the target system? *(Reconnaissance & Scanning)*

- ▶ What can an intruder *do* with that information? (*Gaining & Maintaining Access*)
- ▶ Does anyone at the target *notice* the intruder's attempts or successes? (*Reconnaissance & Covering Tracks*)
- ▶ Are all parts of the information system *properly protected, updated, and patched*?
- ▶ How much *effort, time, and money* is needed to get adequate protection?
- ▶ Are the information security measures in *compliance* with industry and legal standards?

4 Hacking Terminology (Key Concepts)

Term	Meaning
Hack Value	The idea among hackers that something is <i>worth doing</i> or interesting.
Vulnerability	A weakness, design flaw, or implementation error that can lead to an unexpected event that compromises system security.
Exploit	Breaking IT system security by using vulnerabilities.
Payload	The part of exploit code that performs the actual malicious action (destroying data, creating backdoors, hijacking a system).
Zero-Day Attack	An attack that exploits vulnerabilities <i>before</i> the software developer has released a patch. Extremely dangerous because there is no defence yet.
Daisy Chaining	Getting access to one network/computer and then using that access (foothold) to reach multiple other networks that contain valuable information.
Doxing	Posting or sharing someone's personally identifiable information (PII), collected from publicly available databases and social media.
Bot	A software application that can be controlled remotely to run or automate predefined tasks.

4.1 The Five Phases of Hacking

Phase 1 — Reconnaissance

Goal: Collect as much information as possible about the target *before* starting an attack.

- **Passive Reconnaissance** — Collecting information *without* directly interacting with the target (e.g., searching public records, news releases, WHOIS lookups).
- **Active Reconnaissance** — Interacting with the target directly by any means (e.g., calling the help desk, social engineering staff).

Target range may include the organization's clients, employees, operations, network, and systems.

Phase 2 — Scanning

Goal: Use information gathered during reconnaissance to scan the network for specific details.

This is the *pre-attack phase*. The attacker uses tools such as:

- Port scanners, network mappers, ping tools, vulnerability scanners, dialers.

Information collected can include: live machines, open ports, port status, OS details, device type, and system uptime — all used to plan the attack.

Phase 3 — Gaining Access

Goal: Exploit discovered vulnerabilities to obtain access to the system.

- Access can be at the *OS level*, *application level*, or *network level*.
- The attacker can escalate privileges to gain complete control.
- Examples: password cracking, buffer overflows, denial of service, session hijacking.

Phase 4 — Maintaining Access

Goal: Keep control of the compromised system so it can be used later.

- Attackers secure exclusive access using **Backdoors**, **Rootkits**, or **Trojans**.
- They can upload, download, or manipulate data, applications, and configurations.
- The compromised system can be used to launch *further attacks* on other systems.

Phase 5 — Covering Tracks

Goal: Hide evidence of malicious activity to avoid detection and prosecution.

- Attacker's intentions: keep access, remain unnoticed, and delete evidence.
- The attacker overwrites server, system, and application *logs* to avoid suspicion.

Key principle: Attackers always cover tracks to *hide their identity*.

5 Incident Management

Incident Management

Incident management is a **set of defined processes** used to *identify, analyze, prioritize, and resolve* security incidents. The aim is to restore normal service operations as quickly as possible and *prevent the incident from happening again*.

5.1 Components of Incident Management

Left Side

- Vulnerability Handling
- Artifact Handling
- Announcements
- Alerts

Right Side

- Incident Handling:
 - Triage
 - Reporting & Detection
 - Incident Response
 - Analysis
- Other Incident Management Services

5.2 Eight Steps of Incident Handling

Step 1: Preparation — get ready for incident handling and response.

Step 2: Detection and Analysis — find the incident and understand it.

Step 3: Classification and Prioritization — classify it and decide how severe it is.

Step 4: Notification — inform the relevant stakeholders.

Step 5: Containment — stop the incident from spreading further.

Step 6: Forensic Investigation — collect and analyze evidence.

Step 7: Eradication and Recovery — remove the threat and restore systems.

Step 8: Post-Incident Activities — review lessons learned; improve defenses.

5.3 Responsibilities of the Incident Management Team

- Managing security issues proactively and responding effectively to information security incidents.
- Providing a *single point of contact* so incidents can be reported easily.

- Developing and reviewing the processes and procedures to follow during an incident.
- Monitoring legal and regulatory requirement changes so procedures remain valid.
- Managing the response to reduce, control, and limit damage.
- Reviewing existing controls and recommending technologies to *prevent future incidents*.
- Identifying and analyzing what happened during an incident, including impact and threat assessment.
- Building relationships with local law enforcement, government agencies, key partners, and suppliers.

6 Vulnerability Assessment

Vulnerability Assessment

Vulnerability assessment is an **examination of how well a system or application can resist attacks**, including the current security procedures and controls. It identifies, measures, and classifies security vulnerabilities in a computer system, a network, and communication channels.

A vulnerability assessment may be used to:

- **Find weaknesses** that attackers could exploit.
- **Estimate the effectiveness** of extra security measures in protecting information resources from attack.

6.1 Types of Vulnerability Assessment

Type	Description
Active Assessment	Uses a network scanner to find hosts, services, and vulnerabilities by actively probing.
Passive Assessment	Sniffs network traffic to find active systems, services, applications, and vulnerabilities without sending probes.
Host-Based Assessment	Determines vulnerabilities in a specific workstation or server.
Internal Assessment	Scans the internal infrastructure to find exploits and vulnerabilities from inside the network.
External Assessment	Checks the network from a hacker's viewpoint to see what exploits are reachable from outside.
Application Assessment	Tests the web infrastructure for misconfiguration and known vulnerabilities.
Network Assessment	Determines possible network security attacks that may happen on the organization's systems.
Wireless Network Assessment	Identifies vulnerabilities in the organization's wireless networks.

6.2 Network Vulnerability Assessment Method (5 Phases)

Phase I: Acquisition — Collect documents; review laws, procedures, and previously discovered vulnerabilities related to network security.

Phase II: Identification — Interview customers and employees involved in system architecture and administration; gather technical information about all network components; identify applicable industry standards.

Phase III: Analyzing — Review interviews; analyze results of previous assessments; analyze security vulnerabilities and identify risks; perform threat and risk analysis; check the effectiveness of existing security controls and policies.

Phase IV: Evaluation — Estimate how likely identified vulnerabilities are to be exploited; identify gaps between existing and required security measures; de-

termine the controls required to reduce/mitigate vulnerabilities; identify necessary upgrades to the process.

Phase V: Generating Reports — Present results in a draft report for further review. The report should contain: tasks done by each team member, methods used and findings, general and specific recommendations, terms and definitions, and information collected across all phases.

6.3 Vulnerability Research

Vulnerability Research

The process of **finding vulnerabilities and design flaws** that can open an operating system and its applications to attack or misuse. Vulnerabilities are classified based on **severity level** (low, medium, or high) and **exploit range** (local or remote).

An administrator needs vulnerability research:

- To gather information about security *trends, threats, and attacks*.
- To find *weaknesses* and warn the network administrator before a network attack happens.
- To get *information* that helps prevent security problems.
- To understand *how to recover* after a network attack.

Useful Vulnerability Research Websites: CodeRed Center (eccouncil.org), Microsoft Vulnerability Research (technet.microsoft.com), SecurityFocus, HelpNet Security, HackerStorm, SC Magazine, Computerworld, HackerJournals, WindowsSecurity.

7 Penetration Testing

Penetration Testing

Penetration testing (pen testing) is a method of **evaluating the security of an information system or network by simulating an attack** to find out vulnerabilities that an attacker could exploit. Security measures are actively analyzed for design weaknesses, technical flaws, and vulnerabilities. A pen test not only *points out vulnerabilities* but also **documents how the weaknesses can be exploited**. Results are delivered in a complete *report* for both executive management and technical audiences.

7.1 Why Penetration Testing?

- Identify threats that an organization's information assets may face.
- Reduce IT security spending; improve Return on Security Investment (ROSI).
- Provide a complete assessment of the organization's security posture.
- Gain and maintain certification to industry regulations (BS7799, HIPAA, etc.).
- Follow best practices while staying compliant with legal and industry regulations.
- Test and validate how effective security protections and controls are.
- Evaluate the impact of changing or upgrading existing infrastructure.
- Focus on high-severity vulnerabilities; highlight application-level security issues.
- Provide preparation steps to prevent future exploitation.
- Evaluate how effective network security devices are (firewalls, routers, web servers).

7.2 Types of Penetration Testing

Type	Knowledge Level	Description
Black-Box Testing	No prior knowledge	Tester has no information about the infrastructure. Simulates an <i>external</i> attacker. Includes <i>Blind Testing</i> and <i>Double Blind Testing</i> .
White-Box Testing	Complete knowledge	Tester has full information about the infrastructure (network diagrams, source code, etc.). Most thorough type.
Grey-Box Testing	Limited knowledge	Tester has partial information about the infrastructure. Simulates an <i>insider threat</i> .

7.3 Phases of Penetration Testing

Pre-Attack Phase

- **Planning and preparation** — Define scope, goals, and rules of engagement.
- **Methodology designing** — Choose the tools and techniques to be used.
- **Network information gathering** — Collect target-specific data.

Attack Phase

- **Penetrating the perimeter** — Break through the outer defences (firewall, DMZ).
- **Acquiring the target** — Gain initial access to the target system.
- **Escalating privileges** — Move from limited access to administrative access.
- **Execution, implantation, retracting** — Execute the payload, implant backdoors if required, and cleanly exit.

Post-Attack Phase

- **Reporting** — Document all findings, vulnerabilities discovered, and how they were exploited.
- **Clean-up** — Remove all tools, payloads, and changes made during testing.
- **Artifact destruction** — Ensure no test artifacts remain on the target system.

7.4 Types of Penetration Tests (Scope-Based)

From slides, penetration testing can be conducted across many domains:

- Information Gathering
- Vulnerability Analysis
- External Network Penetration Testing
- Internal Network Penetration Testing
- Firewall Penetration Testing
- IDS Penetration Testing
- Password Cracking Penetration Testing
- Social Engineering Penetration Testing
- Web Application Penetration Testing
- SQL Penetration Testing
- Router & Switches Penetration Testing
- Wireless Network Penetration Testing
- Denial-of-Service Penetration Testing
- Stolen Laptop / Mobile Device Penetration Testing
- Source Code Penetration Testing
- Physical Security Penetration Testing
- Surveillance Camera Penetration Testing
- Database Penetration Testing
- VoIP Penetration Testing
- VPN Penetration Testing
- Cloud Penetration Testing
- Virtual Machine Penetration Testing
- Virus & Trojan Detection
- Log Management Penetration Testing
- Mobile Device Penetration Testing
- Email Security Penetration Testing
- Data Leakage Penetration Testing
- SAP Penetration Testing

8 Quick Reference Summary

Key Takeaways from Lecture 02

- ✓ Cyber crime includes many kinds of illegal activities using computers and networks.
- ✓ Attacks follow the formula: **Motive + Method + Vulnerability**.
- ✓ Hackers are grouped by intent: *Black Hat (malicious)*, *White Hat (ethical)*, *Gray Hat (mixed)*.
- ✓ Ethical hacking is authorized security testing — it requires written permission.
- ✓ The five hacking phases are: **Reconnaissance** → **Scanning** → **Gaining Access** → **Maintaining Access** → **Covering Tracks**.
- ✓ Incident management has 8 steps, from preparation through post-incident review.
- ✓ Vulnerability assessment finds and classifies weaknesses before attackers exploit them.
- ✓ Penetration testing simulates real attacks to check how well defences hold up.
- ✓ The three pen test types are: **Black-Box** (no info), **White-Box** (full info), **Grey-Box** (partial info).
- ✓ Every penetration test has three phases: **Pre-Attack**, **Attack**, **Post-Attack**.

End of Lecture 02 Notes

CSE-4207 Cyber Security & Digital Forensics | Jashore University of Science & Technology